

FridgeReady

Privacy Engineering · Supply Chain Security · ISO 27001 Control Mapping · Risk Register · Incident Response

GDPR Article 9 · Explicit Consent · Data Minimisation · RLS · DPIA/RoPA · Vendor Risk · Annex A Controls · Incident Lifecycle

Field	Detail
Project	FridgeReady — meal planning PWA for families with dietary restrictions
Stack	Next.js 14 · Supabase (PostgreSQL + RLS) · Claude API · Stripe · Vercel
Compliance scope	GDPR Articles 5, 6, 7, 9, 12–14, 17, 25, 30, 35 · Privacy by Design
Security scope	RLS · API key management · Input validation · Prompt injection defence · Sentry scrubbing · CSP · Vendor risk assessment
GRC scope	ISO 27001 Annex A control mapping · Risk register · Incident response planning · Supply chain assurance
Portfolio purpose	Demonstrate GRC methodology, security architecture, and compliance documentation for InfoSec roles

Contents

Part A Privacy Engineering

- A.1 GDPR Data Classification
- A.2 Article 9 Special Category Analysis
- A.3 Consent Architecture
- A.4 Data Minimisation
- A.5 Row-Level Security and Technical Controls
- A.6 DPIA and RoPA

Part B Supply Chain Security Assurance

- B.1 Vendor Assessment Framework
- B.2 Vendor Risk Register — Supabase, Stripe, Sentry, Plausible
- B.3 Supply Chain Risk Summary

Part C ISO 27001 Annex A Control Mapping

- C.1 Organisational Controls (5.x) — 7 controls
- C.2 People Controls (6.x) — 2 controls
- C.3 Technological Controls (8.x) — 14 controls

Part D Risk Register and Incident Response Planning

- D.1 Risk Assessment Methodology
- D.2 Risk Register — 6 risks rated by likelihood and impact
- D.3 Incident Response Plans — R1 Data Access / R2 Sentry Leakage / R3 AI Output Error

Part E Honest Scope Boundaries

Context

FridgeReady is a side project — a meal planning Progressive Web App for families managing multiple dietary restrictions. It was designed to address a gap no existing application covers: multiple overlapping dietary restrictions, per-member needs, baby-appropriate portions, and local supermarket integration.

This case study documents the compliance and security engineering decisions made during the design phase of FridgeReady. It is presented as a GRC portfolio piece — demonstrating the ability to reason through real compliance decisions, apply security controls at the architecture level, assess third-party suppliers, map implementations to ISO 27001 Annex A, and produce structured risk documentation.

The document is organised into five parts. Part A covers privacy engineering including GDPR data classification, Article 9 consent architecture, and DPIA/RoPA documentation. Part B documents the supply chain security assessment of four third-party processors. Part C maps 23 implemented security controls to ISO 27001:2022 Annex A. Part D contains a risk register rating six identified risks and three incident response plans following the NIST lifecycle. Part E documents scope boundaries honestly.

FridgeReady is a solo developer project, not a commissioned client engagement. The compliance work documented here was conducted without external audit or certification. It represents independent applied reasoning — the same methodology that would be applied within a professional ISMS context.

Executive Summary

FridgeReady is a meal planning side project built for families managing complex dietary restrictions. Because it collects dietary restriction data — which may reveal health conditions under GDPR Article 9 — and processes children's health information, it sits in the highest-risk category of consumer data processing. This case study documents the privacy engineering and security architecture decisions made during the design phase, and demonstrates how those decisions map to recognised GRC frameworks.

Three decisions define the work. First, the Article 9 classification decision: dietary restriction data was systematically analysed and classified as special category health data, requiring explicit consent rather than standard contract performance as the legal basis. This was not a straightforward call — a gluten avoidance might be coeliac disease or personal preference, indistinguishable from the data alone. The conservative position was taken, and the entire consent architecture was designed around it. Second, the Sentry risk identification: error monitoring was identified as a critical data leakage vector — application error reports can contain stack traces with Article 9 health fields. A beforeSend scrubbing hook was designed and verified before go-live, reducing a Critical inherent risk to Low residual. Third, the consent architecture separation: a meaningful distinction was drawn between processing that required Article 9 explicit consent (AI personalisation using health data) and processing that could be justified under contract performance (restriction filtering). This distinction made a two-mode application possible — one where users who decline Article 9 consent still receive a fully functional product.

The document is structured across five parts. Part A summarises the privacy engineering decisions. Part B documents structured vendor risk assessments for four third-party processors using ISO 27001-aligned criteria. Part C maps 23 implemented security controls to ISO 27001:2022 Annex A. Part D presents a formal risk register with six risks rated by likelihood and impact, and three incident response plans following the NIST SP 800-61 lifecycle. Part E documents scope boundaries honestly.

This is a solo developer project assessed without external audit or certification. The value of the work lies in the methodology — the ability to identify risks before they materialise, apply recognised frameworks to real decisions, and document reasoning in a form that supports audit and review.

Part A — Privacy Engineering

Privacy engineering is the practice of building data protection requirements into a system's architecture from the outset, rather than applying controls retrospectively. GDPR Article 25 makes this a legal obligation for any system processing personal data. The sections below document the key privacy engineering decisions made during FridgeReady's design phase — before any application code was written.

The most consequential decision in this section is the Article 9 data classification in A.1 and A.2. Every subsequent design choice — the consent architecture, the schema design, the AI context block, the RLS policies — flows from that initial classification decision.

A.1 GDPR Data Classification

Data field(s)	Classification	Legal basis
Email, locale, subscription status	Personal data (Art. 6)	Contract performance
Dietary restrictions, allergens	Special category health data (Art. 9)	Explicit consent
Baby DOB, BLW style, doctor-advised foods	Special category health data (Art. 9) — children	Explicit consent
Religious/cultural prefs (Halal, Kosher, Jain)	Special category religious belief (Art. 9)	Explicit consent
Meal ratings, week history	Health-adjacent (indirectly reveals restrictions)	Explicit consent
Stripe customer ID, billing records	Financial data	Legal obligation (Finnish tax law, 7 years)

A.2 Article 9 Classification Decision

Dietary restriction data was classified as Article 9 special category health data using a conservative, risk-based approach: where data could reveal a health condition (e.g. gluten avoidance potentially indicating coeliac disease), it was treated as health data and the higher consent standard applied. This is the defensible position under Article 25 Privacy by Design.

A.3 Consent Architecture

Explicit consent gate designed as a genuine product choice between Personalised mode (Article 9 consent) and Basic mode (contract performance only). Both modes deliver a fully functional application — Basic mode is not a punishment for declining consent. Consent is freely given, specific, informed, unambiguous, and withdrawable at any time via Settings.

A.4 Data Minimisation

Schema design explicitly excluded: specific medical diagnosis, allergy severity, medication data, and date of diagnosis. AI context block capped at 2KB — baby DOB stored in database only; age in months calculated at runtime and sent to API. Raw free text never enters AI prompts — normalised tags only.

A.5 Row-Level Security and Technical Controls

RLS enforced at database layer on all tables using `auth.uid() = user_id` policy pattern. API keys server-side only. All Claude and Stripe calls via Next.js API routes. Sentry `beforeSend` hook strips all Article 9 fields before transmission. CSP headers via `vercel.json`. Input validation and HTML stripping at every API boundary. Prompt injection defence via normalised tag-only context block.

A.6 DPIA and RoPA

DPIA conducted during design phase before any application code touching real user data. Covered: nature and purpose, necessity and proportionality, risk identification (inference of conditions, unauthorised access, function creep, AI output errors), mitigation measures, and residual risk acceptance. RoPA entry documents legal basis, retention periods, third-party recipients, and technical security measures for each processing activity.

Part B — Supply Chain Security Assurance

Every organisation that processes personal data relies on third parties — cloud providers, payment processors, monitoring tools, analytics platforms. Each of those relationships is a potential risk vector: data may be stored in the wrong jurisdiction, processed without adequate contractual protections, or exposed through the processor's

own security failures. Supply chain security assurance is the discipline of systematically identifying and managing those risks before they become incidents.

FridgeReady integrates four third-party processors. Each was assessed before integration using a structured framework of seven questions, derived from GDPR Article 28 requirements and ISO 27001 Annex A.5.19 (information security in supplier relationships). The most significant finding from this assessment was the Sentry risk — identified as Critical at inherent level, reduced to Low through a specific technical control implemented before go-live. The full assessment is documented below.

B.1 Vendor Assessment Framework

The following questions were applied to each processor before integration:

- Data location: where is data stored, processed, and transferred? Does it remain within the EEA?
- Contractual basis: is a Data Processing Agreement (DPA) in place? Does it meet GDPR Article 28 requirements?
- Compliance posture: what certifications or audits does the processor hold (ISO 27001, SOC 2 Type II)?
- Data minimisation: what data does the processor actually receive? Can this be reduced?
- Incident notification: does the processor commit to notifying data breaches within 72 hours as required by GDPR Article 33?
- Sub-processor transparency: are sub-processors disclosed? Are they also contractually bound?
- Termination and deletion: can data be exported and deleted upon contract termination?

B.2 Vendor Risk Register

Supabase — Database and Authentication

Assessment criterion	Finding	Risk	Control / Decision
Data location	Frankfurt, Germany (eu-central-1) — confirmed in Supabase docs	Low	EU data residency confirmed. Data never leaves EEA. Verified before selecting region.
DPA availability	Supabase DPA available and must be signed before processing personal data	Low (with action)	DPA signing is a mandatory pre-beta gate item. Confirmation email saved as evidence.
ISO 27001 / SOC 2	SOC 2 Type II compliant and ISO 27001 certified (verified April 2026 at supabase.com/security) . Strong dual compliance posture.	Low	Both SOC 2 Type II and ISO 27001 certification confirmed. Supabase compliance posture is stronger than initially assessed. RLS provides additional defence in depth at application layer.
Data received	All personal and special category data — family profiles, dietary restrictions, meal history	High	Highest-risk processor. Mitigated by: RLS policies ensuring row-level isolation, AES-256 encryption at rest (Supabase default), TLS in transit, and minimal plaintext in application layer.
Sub-processors	AWS (eu-central-1) disclosed. Full sub-processor list published at supabase.com/legal/privacy	Low	Sub-processors reviewed. AWS Frankfurt confirmed. Acceptable.
Incident notification	Supabase commits to	Low	Notification pathway documented. Supabase →

Assessment criterion	Finding	Risk	Control / Decision
	notifying customers of breaches affecting their data		Controller (Sarah Sandström) → supervisory authority within 72 hours.
Termination / deletion	Data export via pg_dump. Full deletion available on account closure.	Low	Export and deletion procedure documented in RoPA.

Stripe — Payment Processing

Assessment criterion	Finding	Risk	Control / Decision
Data location	EU servers available. Stripe is certified under EU-US Data Privacy Framework.	Low	EU server option selected. Cross-border transfer basis: DPF certification.
DPA availability	Stripe DPA available and accepted via Stripe Dashboard	Low	DPA accepted. Confirmation recorded.
ISO 27001 / SOC 2	SOC 1 Type II and SOC 2 Type II certified. PCI DSS Level 1 certified.	Low	Strong compliance posture. PCI DSS Level 1 is the highest payment security certification.
Data received	Payment card details, billing address, Stripe customer ID. FridgeReady retains only Stripe customer reference ID — no raw card data.	Medium	Minimisation decision: FridgeReady stores only Stripe customer_id. Card numbers, CVV, full payment details never touch FridgeReady infrastructure.
Webhook security	Stripe sends signed webhooks. Signature must be verified.	High (without control)	Stripe-Signature header verification mandatory on every webhook event. Failure to verify is a critical security gap — included in pre-paying-users security gate.
Incident notification	Stripe notifies customers of security incidents affecting their data	Low	Standard DPA commitment confirmed.

Sentry — Error Monitoring

Assessment criterion	Finding	Risk	Control / Decision
Data location	Sentry.io — EU region selected (Frankfurt, Germany). Error events, transactions, and operational data stored in EU. Note: certain account metadata (user accounts, org settings, audit logs, access tokens) stored in US per Sentry's multi-region architecture.	Medium (without full control)	EU region selected for error event storage — the data type most likely to contain Article 9 health fields. Account metadata in US is not personal health data. Risk accepted.
ISO 27001 / SOC 2	SOC 2 Type II and ISO 27001 certified (verified)	Low	Stronger compliance posture than initially documented. SOC 2 Type II and ISO 27001

Assessment criterion	Finding	Risk	Control / Decision
	April 2026 at sentry.io/security). Both certifications confirmed.		both held.
DPA availability	Sentry DPA available at sentry.io/legal/dpa	Low	DPA reviewed and accepted.
ISO 27001 / SOC 2	SOC 2 Type II certified.	Low	Compliance posture adequate for error monitoring use case.
Data received — risk identified	Error reports can contain stack traces, request payloads, and session data — potentially including Article 9 health data if not scrubbed	Critical (without control)	CRITICAL RISK: without scrubbing, health data could appear in error logs transmitted to Sentry. This was identified as the highest-risk processor relationship.
Control implemented	beforeSend hook configured in Week 1 of development. Strips: baby_dob, blw_style, doctor_avoid, doctor_favour, health_goals, religious_prefs, ai_consent_given, ai_consent_given_at, restrictions, allergens, members from all error reports before transmission.	Low (with control)	Health data scrubbing is a mandatory pre-beta gate item. Verified by reviewing Sentry dashboard for absence of health fields in sample error reports.
Minimisation decision	Sentry configured to capture errors only — not session replay or performance monitoring, which would capture more user data.	Low	Principle of minimisation applied to Sentry configuration, not just schema design.

Plausible Analytics — Usage Analytics

Assessment criterion	Finding	Risk	Control / Decision
Data location	Plausible is EU-based (Tallinn, Estonia). All data stored in EU.	Low	EU residency confirmed. No cross-border transfer.
DPA availability	Plausible provides a DPA. Standard contractual terms apply.	Low	DPA accepted.
ISO 27001 / SOC 2	No formal certification. Plausible is open source — code is auditable.	Low-Medium	Offset by: cookieless architecture means no personal data is collected. Open source code reviewed. Risk accepted.
Data received	Aggregate, anonymised usage statistics only. No cookies. No personal identifiers. No cross-site tracking.	Low	Plausible's privacy-by-design architecture means it does not receive personal data. No GDPR Article 13 notice required for analytics. No cookie consent banner needed.
Minimisation decision	Deliberately selected over Google Analytics	Low	Vendor selection itself is a privacy control — choosing a processor that receives no personal

Assessment criterion	Finding	Risk	Control / Decision
	specifically because it processes no personal data.		data eliminates the data protection risk entirely.

B.3 Supply Chain Risk Summary

Processor	Inherent risk	Residual risk	Key control	ISO 27001 relevance
Supabase	High	Low	RLS at database layer + DPA signed + EU region + SOC 2 Type II + ISO 27001 certified	A.8.3 Access restriction · A.5.19 Information security in supplier relationships
Stripe	Medium	Low	Webhook signature verification + no card data stored + PCI DSS Level 1	A.5.19 Supplier relationships · A.8.24 Use of cryptography
Sentry	Critical	Low	beforeSend health data scrubbing hook + EU region (error events) + error-only config + SOC 2 Type II + ISO 27001 certified	A.5.19 Supplier relationships · A.8.12 Data leakage prevention
Plausible	Low	Low	Cookieless — no personal data received by design	A.5.19 Supplier relationships · A.5.12 Classification of information

Part C — ISO 27001 Annex A Control Mapping

ISO 27001 is the international standard for information security management systems. Its Annex A provides a reference set of security controls that organisations can implement to address information security risks. Demonstrating that a system's security architecture maps to recognised Annex A controls serves two purposes: it shows that the controls implemented are not ad hoc but follow an established framework, and it provides the kind of evidence an auditor would look for when assessing whether an ISMS is operating effectively.

This section maps 23 security controls implemented in FridgeReady to their corresponding ISO 27001:2022 Annex A controls. The mapping covers Organisational controls (5.x), People controls (6.x), and Technological controls (8.x). Physical controls (7.x) are not applicable — FridgeReady is a cloud-hosted application with no on-premises infrastructure; physical security is delegated to Supabase (AWS Frankfurt) and Vercel, both of which maintain their own physical security programmes. Supabase holds SOC 2 Type II and ISO 27001 certification (verified April 2026). Vercel relies on AWS infrastructure which holds ISO 27001 and SOC 2 certifications.

For each control, the table documents: the ISO 27001:2022 control reference, the control name, the specific implementation in FridgeReady, and the evidence that implementation exists. The intent is to show not just that controls were designed but that they are verifiable.

ISO 27001:2022 reorganised Annex A from 114 controls in 14 domains to 93 controls in 4 themes: Organisational (5.x), People (6.x), Physical (7.x), and Technological (8.x). The mapping below uses the 2022 structure.

C.1 Organisational Controls (5.x)

ISO 27001:2022 control	Control name	FridgeReady implementation	Evidence
A.5.10	Acceptable use of information and assets	Acceptable use defined in Terms of Service — prohibits reverse engineering, unauthorised access, scraping.	Terms of Service Section 6: Acceptable Use
A.5.12	Classification of information	All data fields classified by GDPR category and sensitivity before schema design. Special category data explicitly flagged in schema (⚠ markers).	Data Classification Table (Part A, Section A.1)
A.5.14	Information transfer	All data transfers encrypted in transit (TLS). No dietary/health data shared with third parties. Data never leaves EEA.	Privacy Policy Section 5 · RoPA third-party recipients field
A.5.17	Authentication information	Password authentication via Supabase Auth. Passwords stored in encrypted form — never visible as plaintext.	Privacy Policy Section 2.1 · Supabase Auth documentation
A.5.19	Information security in supplier relationships	All four third-party processors assessed before integration. DPA signed with each. Sub-processors reviewed. Compliance posture verified.	Part B: Supplier Security Assessment
A.5.20	Addressing information security within supplier agreements	DPA signed with Supabase, Stripe, Sentry, Plausible. Each DPA reviewed for GDPR Article 28 requirements: audit rights, sub-processor disclosure, deletion on termination.	Vendor Risk Register (Part B, Section B.2)
A.5.34	Privacy and protection of PII	Privacy Policy published per GDPR Articles 12–14. All nine data subject rights documented. Contact route provided. Supervisory authority (Finnish DPA) referenced.	Privacy Policy — full document

C.2 People Controls (6.x)

ISO 27001:2022 control	Control name	FridgeReady implementation	Evidence
A.6.3	Information security awareness, education and training	Users informed of data practices via Privacy Policy written to Article 12 readability standard. Consent gate includes plain-language explanation of Article 9 data processing.	Privacy Policy · Consent gate design (Part A, Section A.3)
A.6.8	Information security event reporting	Sentry configured for error monitoring. Users can report security concerns to privacy@fridge-ready.app . Incident response plan defines escalation path.	Privacy Policy Section 9 · Incident Response Plan (Part D)

C.3 Technological Controls (8.x)

ISO 27001:2022 control	Control name	FridgeReady implementation	Evidence
A.8.2	Privileged access rights	No privileged accounts in production application. Supabase service role key stored in Vercel environment variables — never client-side. RLS prevents database-layer privilege escalation.	API Key Management (Part A, Section A.5)
A.8.3	Information access restriction	Row-Level Security enforced at database layer: <code>auth.uid() = user_id</code> on all tables. User A cannot read User B's data even with valid authentication. Tested with two-user cross-access test after every schema migration.	RLS Policy Table (Part A, Section A.5)
A.8.5	Secure authentication	Supabase Auth with email/password. Protected routes via Next.js middleware. Session persistence via secure cookies. No client-side session storage.	Tech Stack (Section A — metadata)
A.8.7	Protection against malware	Input validation and HTML stripping at every API boundary. Prompt injection defence: normalised tags only in AI context block, raw free text never enters prompts. Zod schema validation on all AI output.	AI Safety Controls (Part A, Section A.5)
A.8.9	Management of configuration	Infrastructure-as-code via Vercel configuration. CSP headers defined in <code>vercel.json</code> . Environment variables managed via Vercel dashboard — never committed to repository.	Build Specification Section 7
A.8.10	Information deletion	Article 17 right to erasure: full account deletion flow deletes Stripe subscription, wipes all Supabase tables, deletes Auth user. Consent withdrawal nulls Article 9 fields within the same session.	Privacy Policy Section 8 · Terms of Service Section 12
A.8.11	Data masking	Baby DOB stored in database only. Age in months calculated at runtime — DOB never sent to AI API or error monitoring. Raw dietary restriction text normalised to tags before any external transmission.	Data Minimisation (Part A, Section A.4)
A.8.12	Data leakage prevention	Sentry <code>beforeSend</code> hook strips all Article 9 fields from error reports before transmission. Production build verified to contain no secrets via <code>grep</code> of <code>.next/static/</code> .	Sentry Vendor Assessment (Part B, Section B.2)
A.8.20	Networks security	HTTPS enforced via Vercel (HSTS header). All database connections over TLS. No direct database connections from client — all via Supabase's connection pooler.	Security Non-Negotiables (Part A, Section A.5)
A.8.24	Use of cryptography	AES-256 encryption at rest	Privacy Policy Section 5

ISO 27001:2022 control	Control name	FridgeReady implementation	Evidence
		(Supabase default). TLS in transit for all connections. Passwords stored via Supabase Auth hashing — never as plaintext.	
A.8.25	Secure development lifecycle	Security controls designed before code written (Privacy by Design, Article 25). Pre-beta security gate: 8 mandatory items before any real user accesses system. Pre-paying-users gate: full security sweep including Sentry verification, Stripe webhook test, npm audit.	Build Specification Section 12 — Gate Model
A.8.26	Application security requirements	Security requirements documented in Build Specification before development. Includes: RLS on every table, server-side API calls only, webhook signature verification, health data scrubbing.	Build Specification Section 7 — Security Non-Negotiables
A.8.28	Secure coding	No client-side secrets. HTML stripping on all inputs. Prompt injection defence. Zod validation on AI output. npm audit before every deploy — critical/high issues fixed within 48 hours.	Build Specification Section 7
A.8.29	Security testing in development	Automated tests cover: RLS cross-user isolation, GDPR consent flow, AI context block data minimisation, restriction enforcement, Stripe webhook signature. CI via GitHub Actions — blocks deploy on test failure.	Compliance Testing Strategy (Part A, Section A.5)
A.8.32	Change management	Database migrations in supabase/migrations/ — reviewed before running. Claude Code instructed never to modify migration files without explicit approval. Version control via GitHub.	Build Specification Section 12.4
A.8.34	Protection of information systems during audit testing	Test suite uses synthetic household fixtures (FAMILY_GF_BABY etc) — no real user data ever used in testing. MSW intercepts all external API calls in tests — no real API calls made during test runs.	Compliance Testing Strategy (Part A, Section A.5)

Coverage note: Physical controls (7.x) are not applicable to FridgeReady as a cloud-hosted PWA with no on-premises infrastructure. Physical security is delegated to Supabase (AWS Frankfurt) and Vercel infrastructure, both of which maintain their own physical security controls documented in their SOC 2 reports.

Part D — Risk Register and Incident Response Planning

Risk management is the process of identifying what can go wrong, assessing how likely and how bad it would be, implementing controls to reduce the risk to an acceptable level, and documenting the residual risk that remains. In an ISO 27001 context, this process is formalised as the information security risk assessment and

treatment process (Clauses 6.1.2 and 6.1.3). In a GDPR context, it is part of the Data Protection Impact Assessment required under Article 35 for high-risk processing.

FridgeReady's risk assessment was conducted during the design phase, before application code was written. Six risks were identified across the threat landscape: unauthorised data access, health data leakage via error monitoring, AI output allergen errors, prompt injection, payment fraud, and function creep. Each risk was rated on a 5×5 likelihood-impact matrix, mitigated with specific technical or organisational controls, and re-rated at residual level. Three risks — those with the highest residual exposure — were developed into full incident response plans following the NIST SP 800-61 Rev 2 lifecycle.

D.1 Risk Assessment Methodology

Risk assessment follows ISO 27001 Annex A principles and GDPR Article 35 DPIA requirements. Each risk is rated on two axes:

- Likelihood: Rare (1) / Unlikely (2) / Possible (3) / Likely (4) / Almost Certain (5)
- Impact: Negligible (1) / Minor (2) / Moderate (3) / Major (4) / Catastrophic (5)
- Risk score: Likelihood × Impact. Low = 1–4, Medium = 5–9, High = 10–16, Critical = 17–25

Risks are assessed at inherent level (before controls) and residual level (after controls). Residual risks above Medium require documented acceptance rationale.

D.2 Risk Register

ID	Risk	Inherent risk	Controls implemented	Likelihood	Impact	Residual risk
R1	Unauthorised access to Article 9 health data via compromised user credentials or RLS bypass	Critical (L:3 × I:5 = 15)	RLS on all tables · Two-user isolation test · Supabase Auth · Protected routes · AES-256 at rest · TLS in transit	Unlikely (2)	Major (4)	Medium (8) — Accepted. RLS provides defence in depth independent of application layer. Residual risk is credential compromise, mitigated by Supabase Auth and session management.
R2	Article 9 health data leakage via Sentry error reports	Critical (L:4 × I:5 = 20)	beforeSend hook strips all Article 9 fields · EU Sentry region · Error-only config (no session replay)	Rare (1)	Major (4)	Low (4) — Accepted. beforeSend hook verified in Sentry dashboard. Residual risk is hook misconfiguration, mitigated by pre-beta gate verification requirement.
R3	AI output contains allergen causing harm (incorrect meal suggestion for restricted user)	Critical (L:3 × I:5 = 15)	Zod validation on all AI output · Human review gate before applying to plan · restriction_tags fallback filtering · Health disclaimer on plan screen · Basic mode available without AI	Unlikely (2)	Catastrophic (5)	Medium (10) — Accepted with disclaimer. Human review gate is the critical control. Terms of Service Section 7 (Health Disclaimer) sets legal basis. Automated tests verify restriction enforcement on every deploy.
R4	Prompt injection via user-supplied dietary restriction text entering AI prompts	High (L:4 × I:4 = 16)	Normalised enum tags only in AI context block · Raw free text never enters prompts · HTML stripping at	Rare (1)	Major (4)	Low (4) — Accepted. Architectural control: free text architecturally excluded from AI context block. Not a filtering problem — a

ID	Risk	Inherent risk	Controls implemented	Likelihood	Impact	Residual risk
			API boundary · Zod output validation			design decision.
R5	Stripe payment fraud via webhook spoofing	High (L:3 × I:4 = 12)	Stripe-Signature header verification on every event · Server-side webhook handler only · Unknown event types rejected	Rare (1)	Major (4)	Low (4) — Accepted. Signature verification is a mandatory pre-paying-users gate item. Automated test verifies signature verification logic.
R6	Function creep — dietary health data used for purposes beyond meal planning	Medium (L:2 × I:4 = 8)	Purpose limitation documented in RoPA · No third-party sharing of Article 9 data · Privacy Policy explicitly limits use · No cross-referencing dietary data with behaviour patterns	Rare (1)	Major (4)	Low (4) — Accepted. Purpose limitation is an organisational and contractual control. No technical mechanism for function creep exists in current architecture.

D.3 Incident Response Plan

This plan covers the three highest-residual-risk scenarios identified in the risk register: R1 (unauthorised data access), R2 (Sentry health data leakage), and R3 (AI output allergen error). It follows the NIST incident response lifecycle: Preparation → Detection → Containment → Eradication → Recovery → Lessons Learned.

Incident Type 1 — Unauthorised Access to Health Data (R1)

Phase	Action	Owner	Timeframe
Preparation	RLS cross-user isolation test automated in CI. Supabase audit logs enabled. Incident response contact: privacy@fridge-ready.app .	Developer	Ongoing — pre-launch
Detection	Supabase audit log anomaly (unexpected cross-user queries). User report via privacy@fridge-ready.app . Sentry error spike from RLS policy violation.	Automated monitoring + user report	Within hours
Containment	Immediately rotate Supabase service role key. Temporarily disable affected user accounts via Supabase Auth admin. Preserve Supabase audit logs as evidence.	Developer	Within 1 hour of detection
Assessment	Determine: which data was accessed, by whom, for how long. Review Supabase audit logs. Classify breach severity under GDPR Article 33.	Developer	Within 4 hours
Notification	If personal data breach confirmed: notify Finnish Data Protection Ombudsman within 72 hours (GDPR Article 33). Notify affected users without undue delay if high risk to their rights (Article 34).	Developer / Legal	Within 72 hours

Phase	Action	Owner	Timeframe
Eradication	Fix RLS policy gap. Deploy updated policies. Verify with two-user isolation test. Review all other tables for similar vulnerabilities.	Developer	Within 24 hours of containment
Recovery	Re-enable affected accounts after confirming fix. Monitor for 48 hours for anomalies.	Developer	Within 48 hours of eradication
Lessons Learned	Post-incident review: how was the gap introduced? Was it caught in testing? Update test suite. Update pre-deploy checklist if needed.	Developer	Within 1 week

Incident Type 2 — Health Data Leakage via Sentry (R2)

Phase	Action	Owner	Timeframe
Preparation	beforeSend hook verified in pre-beta gate. Sentry dashboard reviewed for presence of health fields in sample errors before go-live.	Developer	Pre-launch gate item
Detection	Routine Sentry dashboard review identifies Article 9 field in error report. Or: automated alert if known field names appear in Sentry event payload (configurable in Sentry).	Developer	Weekly dashboard review
Containment	Immediately disable Sentry error collection (set SENTRY_DSN to empty string in Vercel environment). This stops further transmission immediately.	Developer	Within 30 minutes
Assessment	Review Sentry events for the period since last clean review. Identify which fields were transmitted and to whom Sentry data is accessible.	Developer	Within 2 hours
Notification	Sentry processes data as a sub-processor. If health data was transmitted: assess whether GDPR Article 33 notification threshold is met. Likely yes given Article 9 category.	Developer / Legal	Within 72 hours if threshold met
Eradication	Fix beforeSend hook. Add automated test that simulates an error containing Article 9 fields and asserts they are stripped before transmission.	Developer	Within 4 hours
Recovery	Re-enable Sentry after fix verified. Monitor for 24 hours.	Developer	Within 24 hours
Lessons Learned	How did the hook break? Was it a deployment issue or a code change? Add to CI pipeline.	Developer	Within 1 week

Incident Type 3 — AI Output Allergen Error (R3)

Phase	Action	Owner	Timeframe
Preparation	Automated tests verify restriction enforcement on every deploy. Restriction_tags fallback filtering active in Basic mode. Health disclaimer visible on plan screen without scrolling.	Developer	Pre-launch gate item
Detection	User report: meal suggestion contains restricted ingredient. Sentry error if Zod validation fails on AI output.	User report	Variable — depends on user noticing
Containment	Immediately disable AI meal suggestions for affected user. Revert to Basic mode (restriction_tags filtering) for that account.	Developer	Within 1 hour of report
Assessment	Reproduce the AI output. Identify: was the restriction in the context block? Did Zod validation pass? Was the human review gate bypassed?	Developer	Within 4 hours
Eradication	Fix the specific failure point. If context block issue: update buildContextBlock.ts and add targeted test. If Zod issue: tighten schema. If UI review gate: reinforce the gate.	Developer	Within 24 hours
Recovery	Re-enable AI suggestions for affected user after fix. Monitor for 48 hours.	Developer	Within 48 hours
User communication	Contact affected user directly. Acknowledge the error. Confirm their restriction profile is correct. Offer to review their meal plan.	Developer	Within 24 hours of detection
Lessons Learned	Update test fixtures to cover the specific scenario that failed. Consider adding the specific meal/restriction combination to the automated test suite.	Developer	Within 1 week

Part E — Honest Scope Boundaries

Intellectual honesty is part of compliance culture. A GRC professional who presents only what went well and omits what was not done is less trustworthy, not more impressive. This section documents what remains outside the current scope of FridgeReady's compliance and security work — and distinguishes between items that are deferred by design, items that would be required before public launch, and items that are simply out of scope for a solo developer project.

These gaps do not undermine the work documented in Parts A through D. They reflect the honest reality that a side project produced by a single developer has different constraints than a commercial product operated by an organisation with dedicated security, legal, and engineering teams. The methodology applied is sound; the coverage is necessarily partial.

Item	Status	Required before
Security penetration testing	Not conducted	Public launch
Full Article 15 subject access request workflow	Partially designed	Public launch
Automated consent expiry	Designed, not implemented	Scale
Finnish localisation	Not built	Finnish market launch
Formal ISO 27001 certification	Not pursued — out of scope for solo project	Enterprise clients
Third-party SOC 2 audit of FridgeReady infrastructure	Not conducted	Enterprise clients
Formal business continuity plan beyond incident response	Not documented	Public launch

Conclusion

FridgeReady began as a product idea and became a compliance engineering exercise. The decision to treat dietary restriction data as Article 9 special category health data — rather than the simpler classification of preference data — set the architectural direction for everything that followed: the two-mode consent architecture, the schema decisions, the AI context block design, and the RLS policies. That one classification decision, and the reasoning behind it, is the most transferable thing in this document.

The supply chain assessment in Part B demonstrated that vendor risk is not just about signing a DPA — it requires understanding what data each processor actually receives, under what conditions it could be exposed, and what specific controls reduce that exposure. The Sentry case is the clearest example: a processor selected for a legitimate purpose (error monitoring) that becomes a critical data leakage vector without a specific architectural control (the beforeSend scrubbing hook). Identifying that risk before go-live, rather than after an incident, is what supply chain security assurance is for.

The ISO 27001 Annex A mapping in Part C demonstrates that the security controls implemented in FridgeReady are not ad hoc — they correspond to recognised controls in the international information security management standard. This matters because it shows the ability to operate within a framework, not just to solve individual problems. A GRC professional needs to be able to explain why a control exists in terms a standard recognises, not just in terms of the specific system it protects.

The risk register and incident response plans in Part D demonstrate structured risk thinking: identifying threats before they materialise, rating them systematically, implementing controls, and documenting what to do when controls fail. The incident plans are not theoretical — they are written for the specific risks of this specific system, with specific containment actions, notification obligations, and recovery steps.

What this document does not demonstrate is equally important to state. It does not demonstrate participation in a formal ISO 27001 audit, experience with SOC 2 compliance in a professional context, or live incident management in a security team. Those are gaps that reflect the difference between applied academic and professional work — gaps that exist at the start of a GRC career, not evidence of unsuitability for it.

The methodology is sound. The reasoning is documented. The frameworks are applied correctly. That is what a case study can demonstrate — and it is what this one sets out to do.

References

Regulatory Frameworks

- European Parliament and Council (2016). Regulation (EU) 2016/679 — General Data Protection Regulation (GDPR). Official Journal of the European Union. Articles 5, 6, 7, 9, 12–14, 17, 25, 28, 30, 33, 34, 35. Available at: eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32016R0679
- European Data Protection Board (2022). Guidelines 9/2022 on personal data breach notification under GDPR. EDPB. Available at: edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-92022-personal-data-breach-notification_en

- European Data Protection Board (2019). Guidelines 07/2020 on the concepts of controller and processor in the GDPR. EDPB. Available at: edpb.europa.eu

Information Security Standards

- International Organization for Standardization (2022). ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Geneva: ISO. Available at: [iso.org/standard/27001](https://www.iso.org/standard/27001)
- International Organization for Standardization (2022). ISO/IEC 27001:2022 Annex A — Information security controls reference. Geneva: ISO.
- International Organization for Standardization (2018). ISO/IEC 27005:2018 — Information security risk management. Geneva: ISO. Available at: [iso.org/standard/75281.html](https://www.iso.org/standard/75281.html)

Incident Response

- Cichonski, P., Millar, T., Grance, T., and Scarfone, K. (2012). NIST Special Publication 800-61 Revision 2 — Computer Security Incident Handling Guide. National Institute of Standards and Technology, US Department of Commerce. Available at: nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf

Audit and Assurance

- American Institute of Certified Public Accountants (2017). SOC 2® — SOC for Service Organisations: Trust Services Criteria. AICPA. Available at: aicpa.org/resources/article/soc-2-for-service-organizations
- Supabase Inc. (2024). SOC 2 Type II Report. Available under NDA to customers at: supabase.com/security
- Stripe Inc. (2024). Stripe Security and Compliance Documentation — SOC 1 Type II, SOC 2 Type II, PCI DSS Level 1. Available at: stripe.com/docs/security

Privacy Engineering and Risk

- Information Commissioner's Office (2020). Guide to Data Protection Impact Assessments (DPIAs). ICO. Available at: ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/data-protection-impact-assessments-dpias
- ENISA (2021). Guidelines for Supply Chain Security — Threat Landscape for Supply Chain Attacks. European Union Agency for Cybersecurity. Available at: enisa.europa.eu/publications/threat-landscape-for-supply-chain-attacks
- Cavoukian, A. (2009). Privacy by Design: The 7 Foundational Principles. Information and Privacy Commissioner of Ontario. Available at: ipc.on.ca/wp-content/uploads/resources/7foundationalprinciples.pdf

Course Materials

- University of London (2023). CM2025 — Computer Security. BSc Computer Science programme. Delivered via Goldsmiths, University of London.
- University of London (2022). CM2045 — Professional Practice for Computer Scientists. BSc Computer Science programme. Delivered via Goldsmiths, University of London.
- ISC2 (2024). Certified in Cybersecurity (CC) — Self-Paced Training. Domain 2: Business Continuity, Disaster Recovery and Incident Response Concepts. Available at: isc2.org/certifications/cc